



CYBER SECURITY PRACTICAL GUIDE

NAME: Chandana Somanath Khatavakar

Web Application Security Projects

SSRF (Server-Side Request Forgery)

Server-Side Request Forgery (SSRF) is a security vulnerability in which an attacker can trick a server into making unauthorized requests on their behalf. SSRF occurs when an application, typically a web server, fetches resources from another server (often based on user input) without sufficient validation. If unprotected, this can lead to various risks, including unauthorized data access, exposure of sensitive information, and even control over internal systems.

How SSRF Works

In SSRF attacks, an attacker typically supplies a URL or IP address that the server will fetch. By manipulating this request, the attacker can:

- Access internal systems or private networks that aren't directly accessible from the internet.
- Perform unauthorized actions on other internal servers.
- Retrieve sensitive data, such as metadata from cloud service providers like AWS.
- Potentially exploit vulnerabilities within internal services.

Common Attack Scenarios

- **Accessing Internal Endpoints:** For example, by entering URLs pointing to internal resources (e.g., `http://localhost`), attackers can interact with internal services that the application itself can access.
- **Accessing Cloud Metadata Services:** Many cloud platforms (e.g., AWS, Google Cloud) have metadata endpoints (e.g., `http://169.254.169.254`) that expose instance-related information. SSRF vulnerabilities can be exploited to access these endpoints and retrieve credentials.
- **Exfiltrating Data:** Attackers might use SSRF to bypass firewalls, gaining access to sensitive data within internal systems or databases.

Tools for Testing SSRF

- **Burp Suite:** With extensions like Collaborator for detecting SSRF vulnerabilities.
- **SSRFmap:** An open-source tool for testing SSRF vulnerabilities and cloud metadata endpoints.

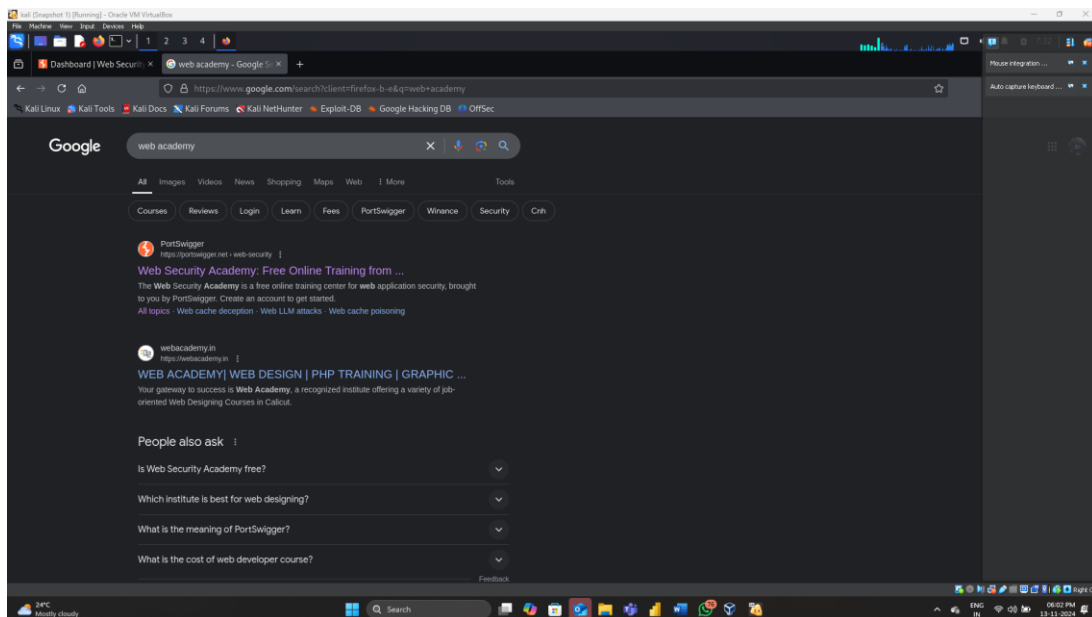
Step1: Ensure you have Kali Linux installed and up to date.

Use Burp Suite Community or Professional for testing. Burp Suite Professional offers additional features that can aid in SSRF detection, like the Collaborator tool.

Step2: Go to this site

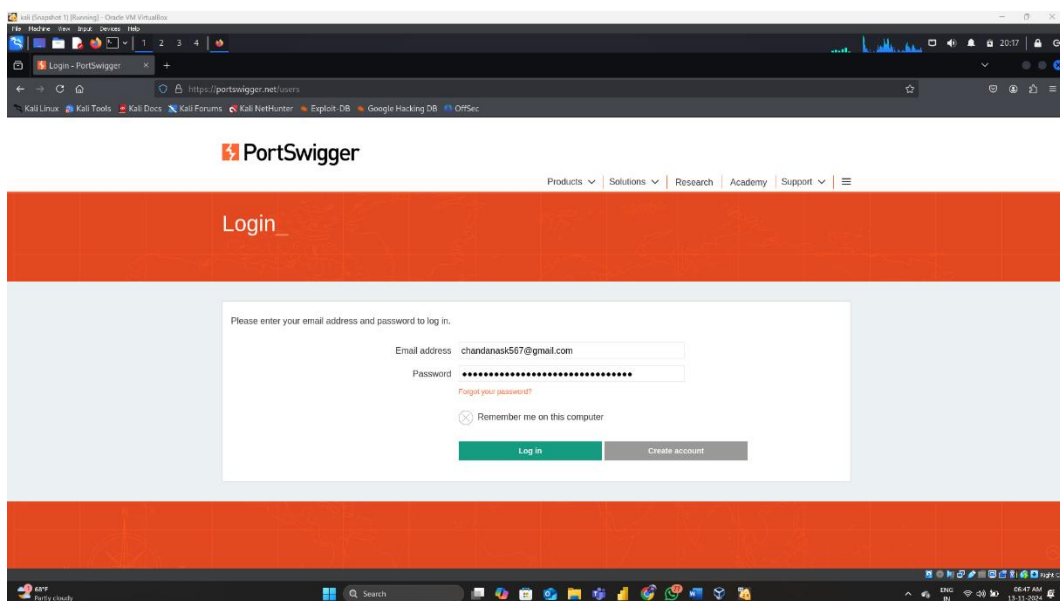
<https://portswigger.net/web-security>

Then click on sign up and give your dummy mail id and then it will through a password copy and save that password in note pad then logout from that website.



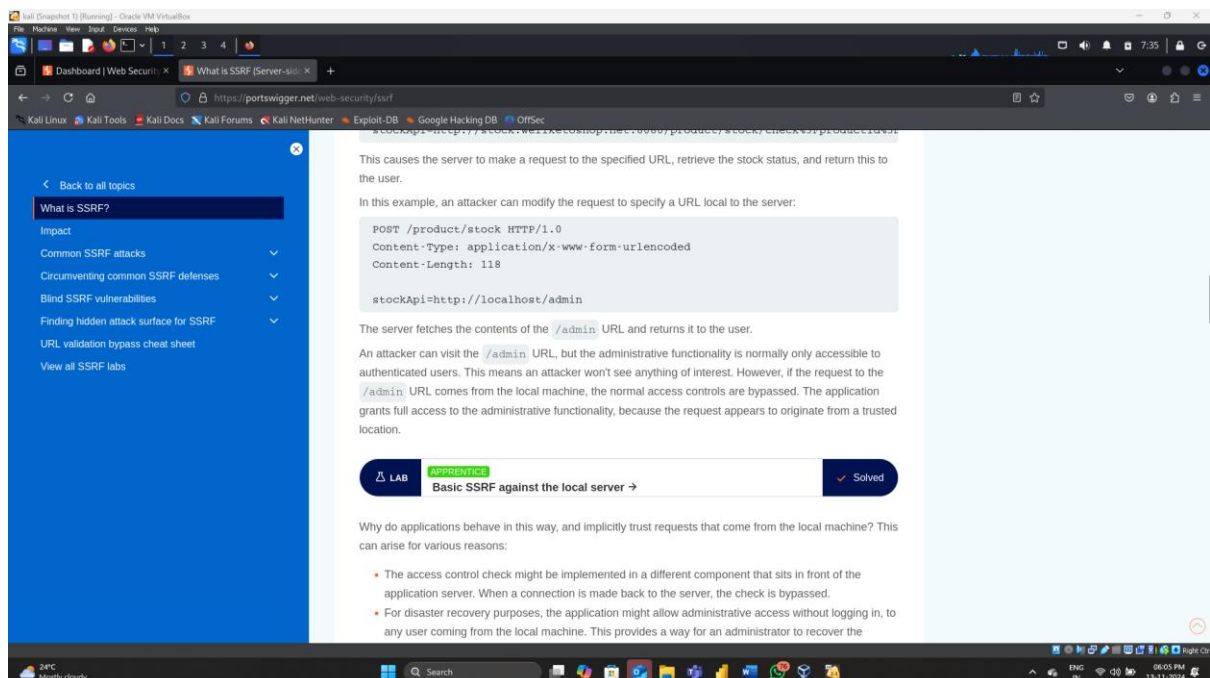
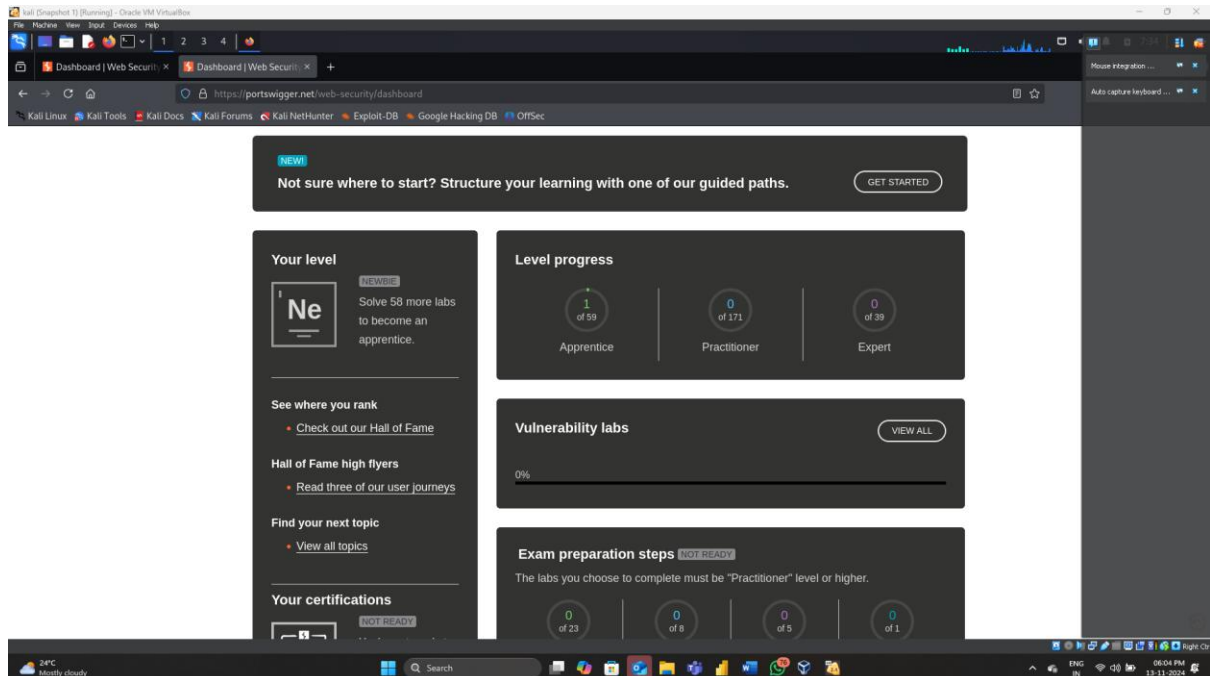
Step3: Then again go to same website and click on Login

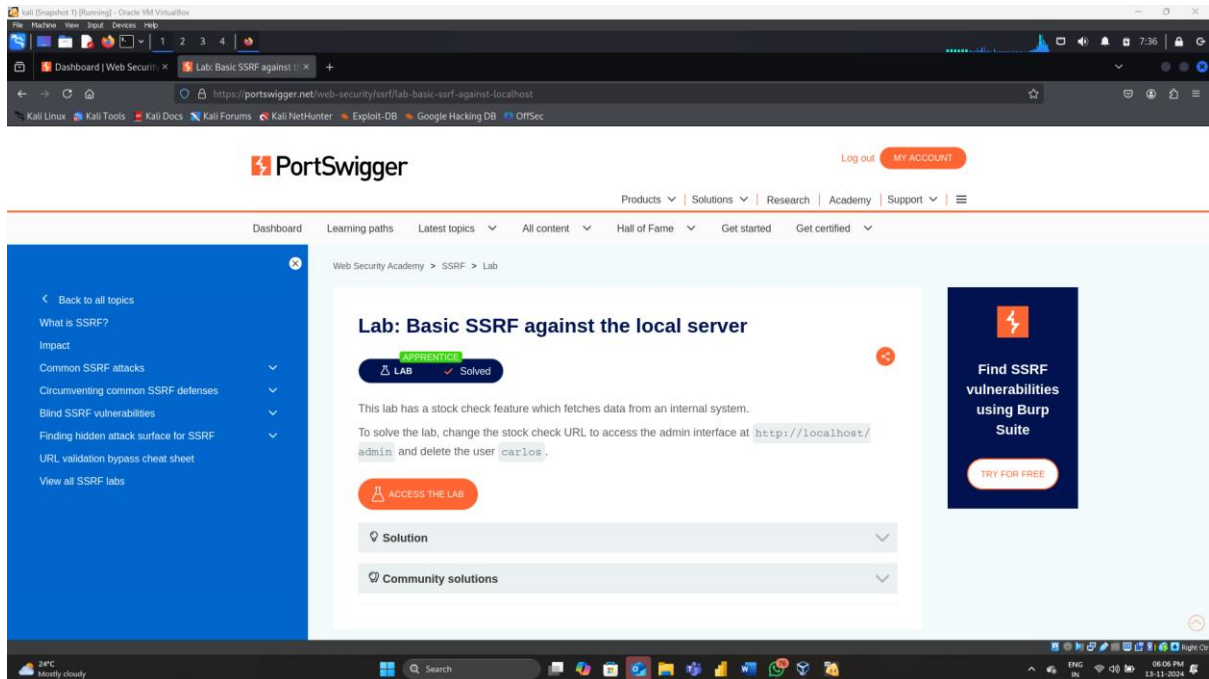
Then enter your email-id and password over there



Step4: After logging in that site then go to Academy section and scroll down then click on view all topics in that go to SSRF

Then scroll down then click on 'Basic SSRF against the local server' then click on Access the Lab

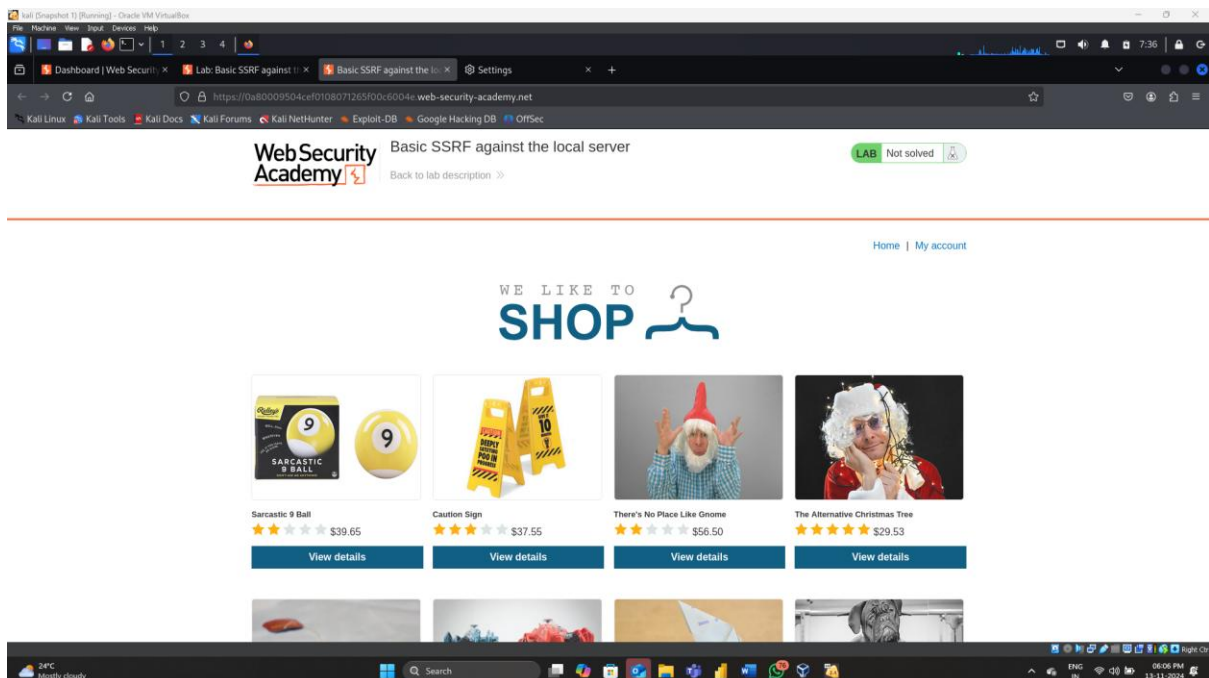




Note: While doing this check the proxy you are in No proxy

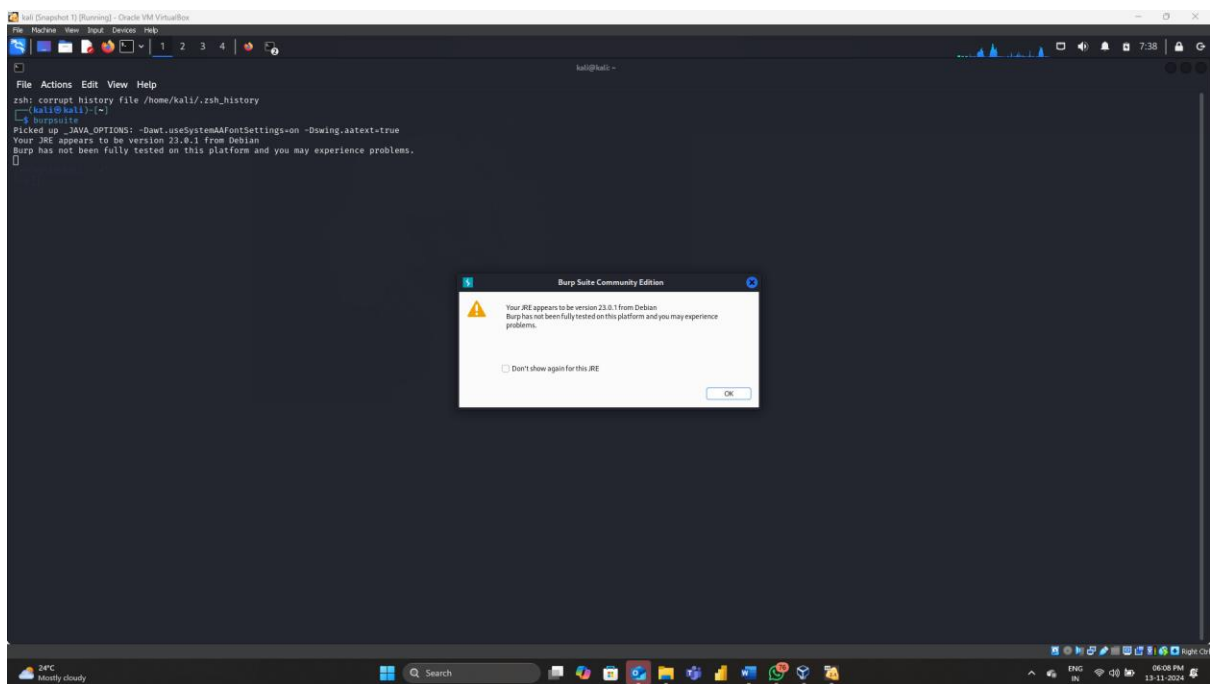
Means It should be in no proxy.

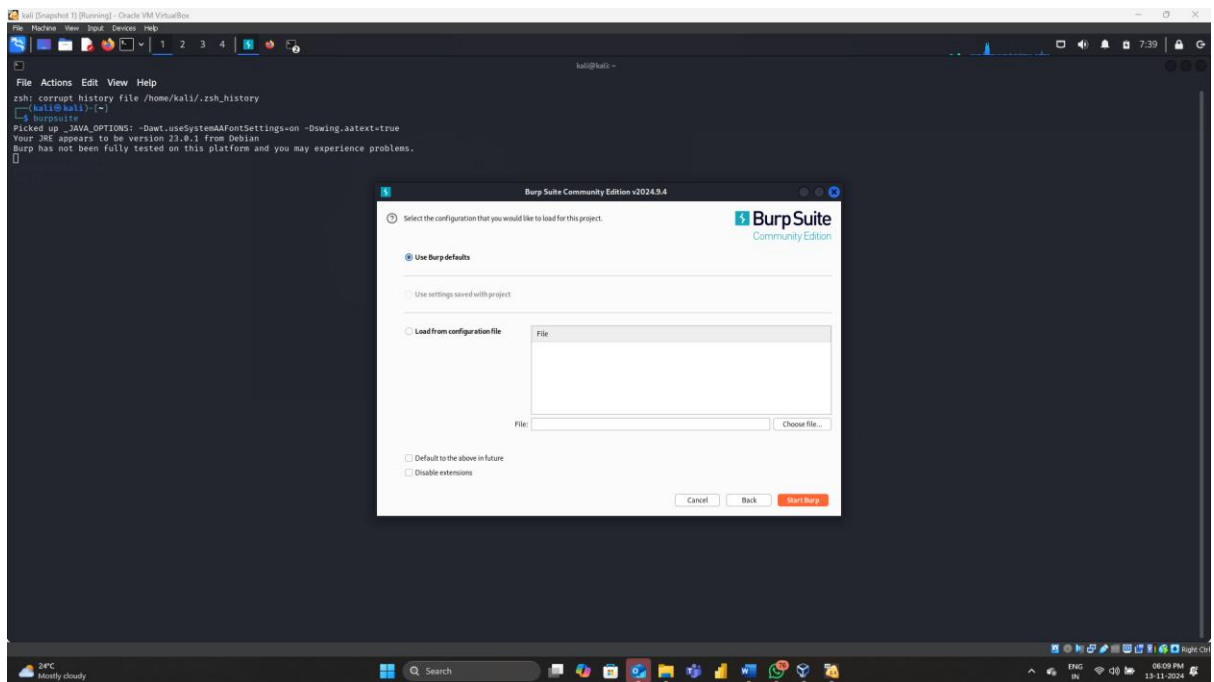
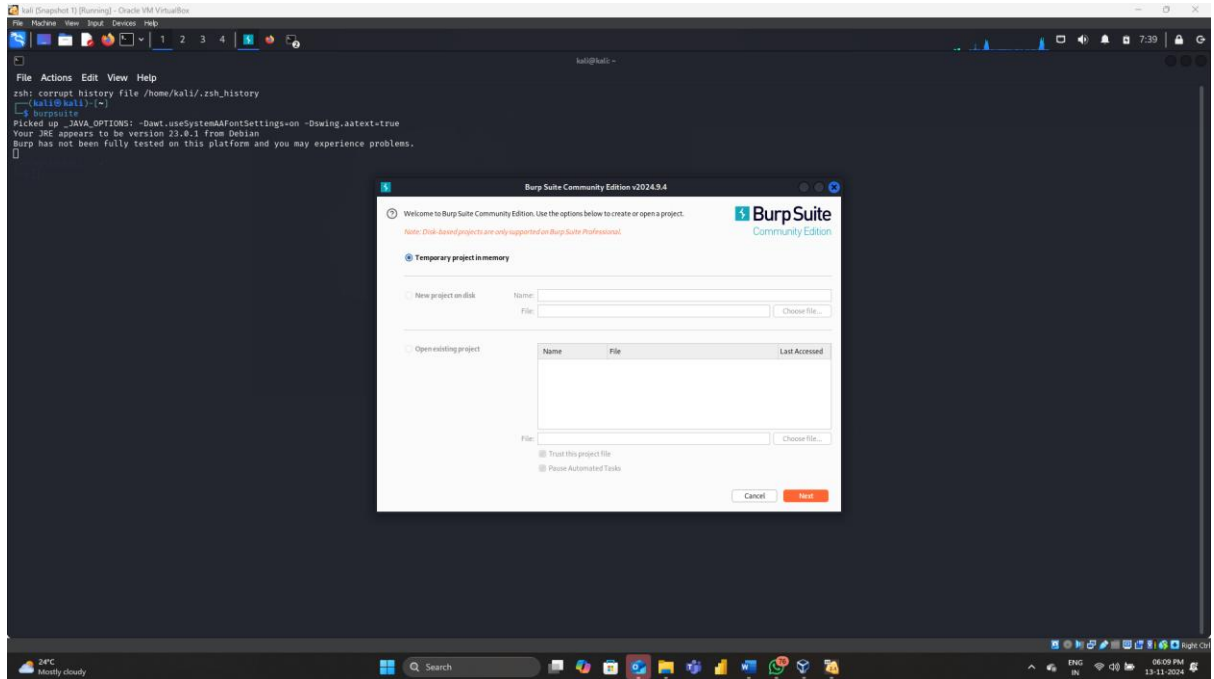
Step5: Then click on any product and check the stock over there

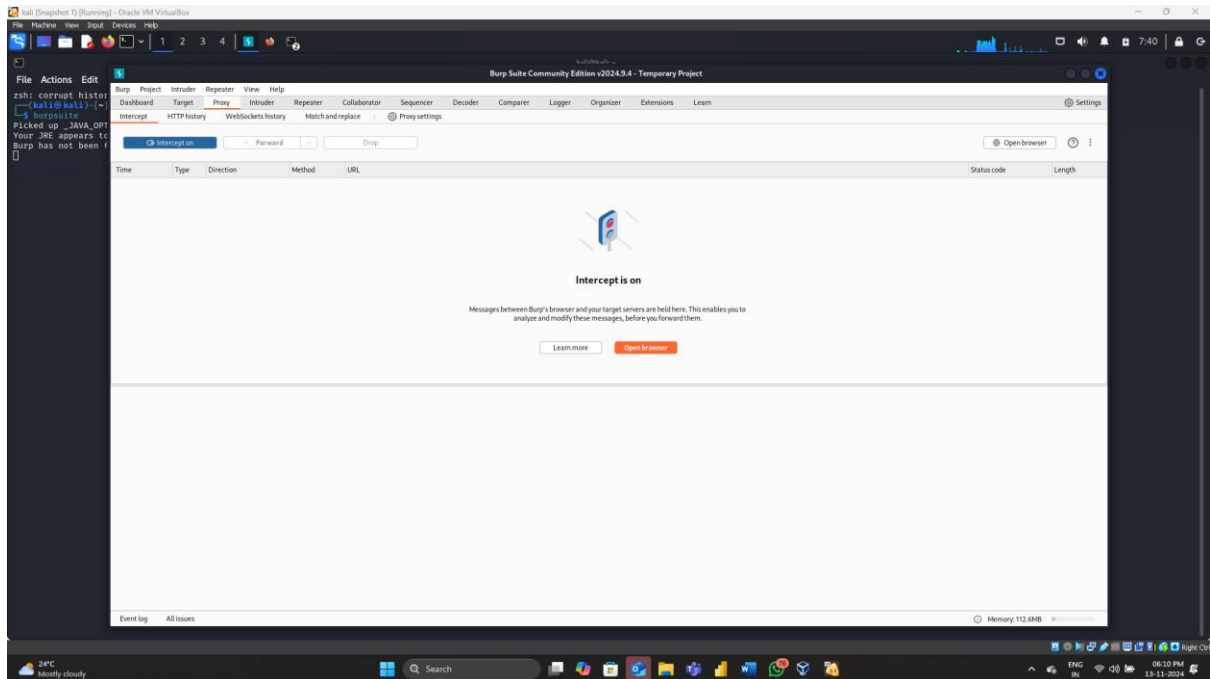




Step6: Then go to Burp suite and turn on the intercept (It should be show like **intercept is on**)

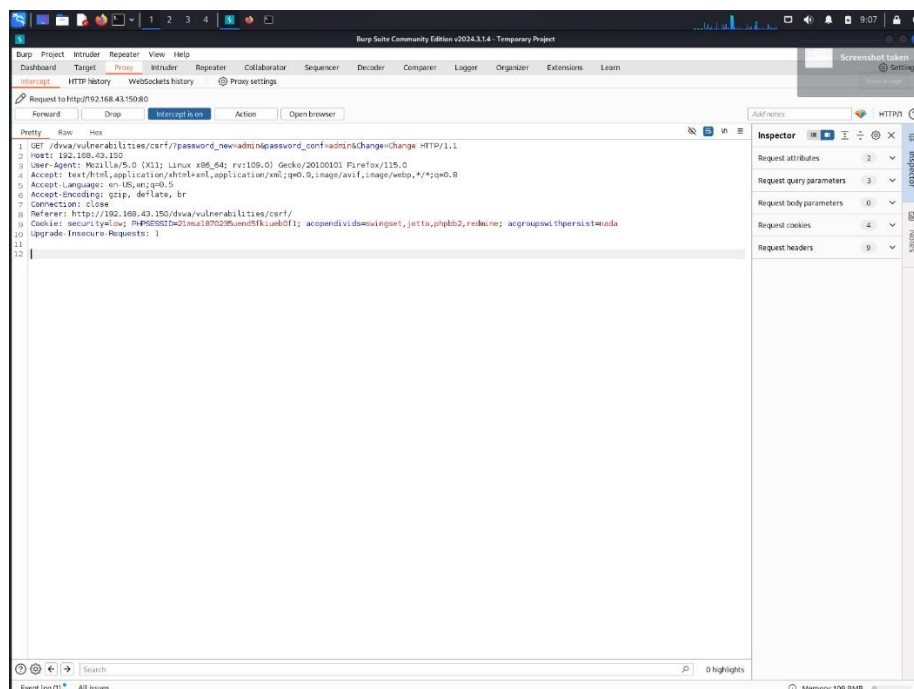




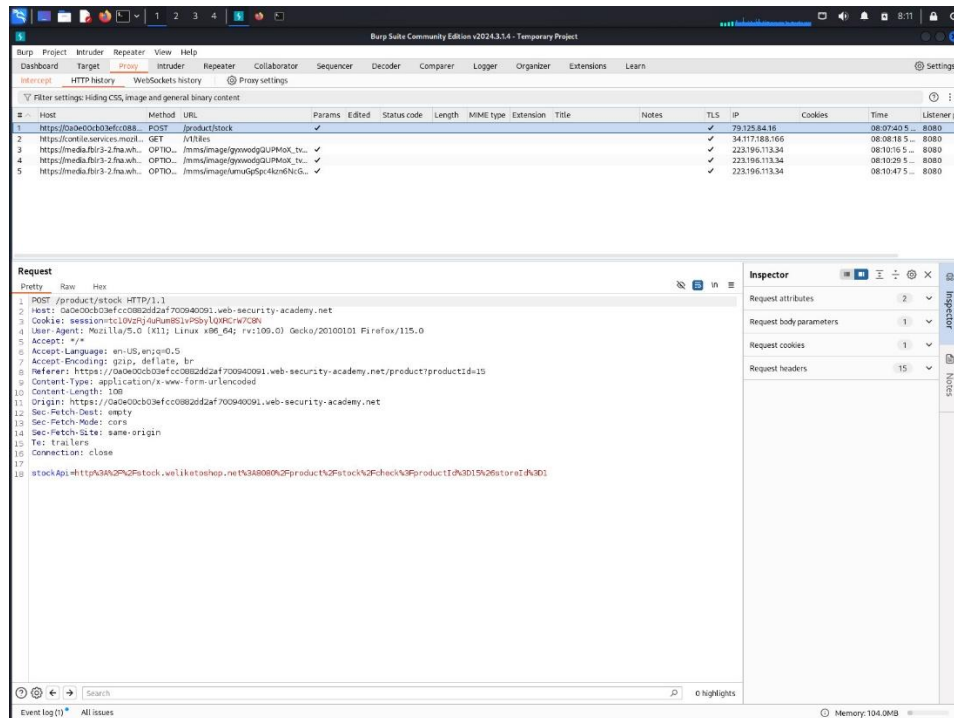


Step7: Make proxy settings as **'Manual'** Then go to Product and again click on check stock

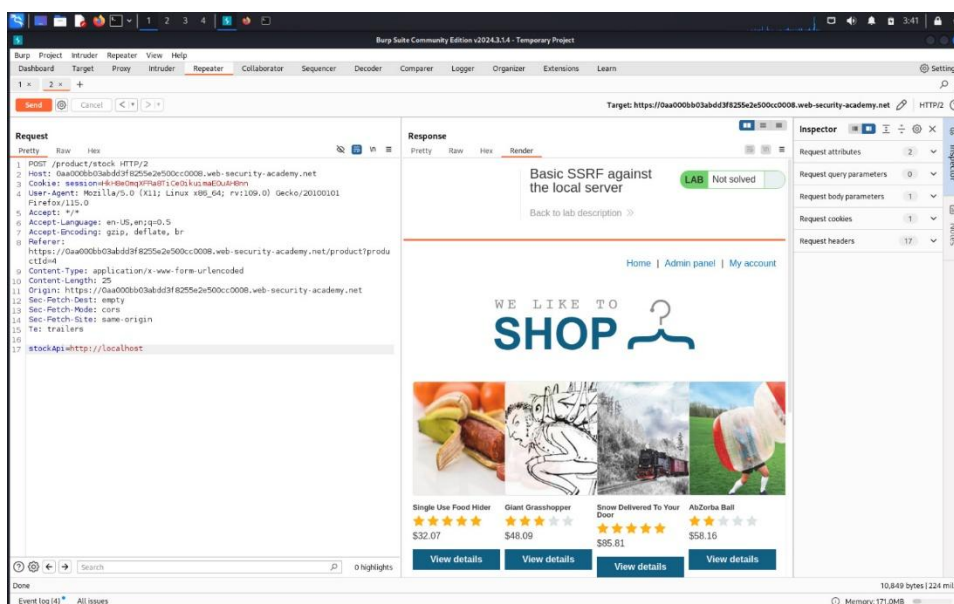
Then it will open like this as below picture



Step8: Then go to HTTP History and click on first site and in the down right click and send to Repeater



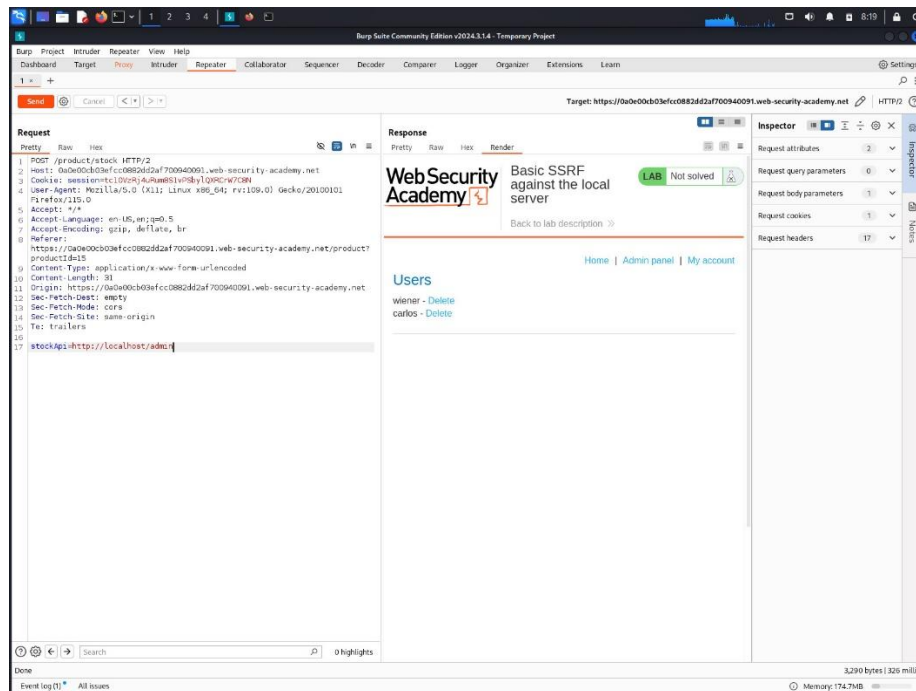
Step9: Then go to repeater section and remove that stock Api then enter like this
stockApi=http://localhost and click on send and click on Render
It should be show like this as below mentioned picture



Observe that carefully there is admin panel is added before in that site it is not there now here that 'Admin Panel' is added

Step10: Again, modify stockApi= <http://localhost/admin>

Then click on send and click on Render it should be show as like below picture

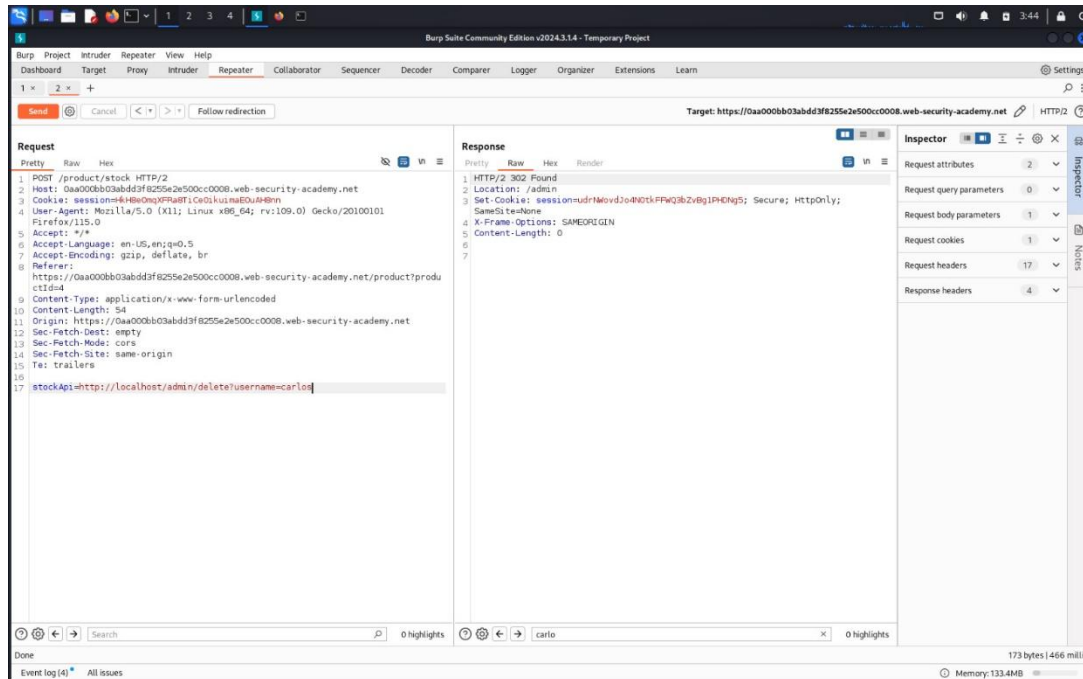


Step11: Our task is to delete the Carlos

Then go to Burp suite and go to pretty and search for Carlos

Then copy that and paste it in stockApi

stockApi= <http://localhost/admin/delete?username=carlos> then click on send and click on Render



Here it should not show anything, so we must remove till admin

stockApi= <http://localhost/admin>

now click on send and click on Render

It should show like this as given below picture

